

Tilington plc — Architecture Principles

Cloud Modernisation Programme · Design Standards

Tilington plc — Architecture Principles

Cloud Modernisation Programme | DRAFT v0.1

> **Status: DRAFT** — Candidate reviews, challenges, and finalises these in Phase 2

These principles **MUST** be applied to every architectural decision in the programme. They are non-negotiable unless formally excepted via an ADR.

Principle 1 — Security by Design

Statement: Security controls are built into every layer. Security is never bolted on after the fact.

Rationale: FCA and PRA expect firms to treat security as a core business requirement, not an afterthought. NCSC Cloud Security Principles 1–14 apply.

Implications:

- All data at rest encrypted with KMS CMKs
 - All data in transit encrypted with TLS 1.2 minimum
 - IAM roles follow least-privilege — no wildcard permissions
 - CloudTrail enabled in all accounts, logs immutable in dedicated S3 bucket
 - GuardDuty and Security Hub active in all accounts from Day 1
-

Principle 2 — Multi-Account Architecture

Statement: Workloads are separated across multiple AWS accounts by environment and function.

Rationale: Blast radius reduction. FCA expects separation of production from non-production. AWS Well-Architected requires account-level isolation for sensitive workloads.

Implications:

- Minimum 6 accounts: Management, Security, Logging, Shared Services, Production, Non-Production
 - SCPs enforce account-level guardrails
 - No production workloads in non-production accounts
-

Principle 3 — Infrastructure as Code

Statement: All infrastructure is defined in code. Nothing is manually provisioned in production.

Rationale: Repeatability, audit trail, compliance. FCA expects reproducible environments.

Implications:

- Terraform for all infrastructure

- CloudFormation permitted for AWS-native bootstrapping only
 - No ClickOps in production accounts
 - All IaC in version control with PR review
-

Principle 4 — Data Residency

Statement: All customer personal data remains in eu-west-2 (London).

Rationale: UK GDPR Article 44 — data transfers outside UK require adequacy decision or appropriate safeguards. EU-west-2 satisfies UK ICO data residency requirements.

Implications:

- Primary region: eu-west-2 only
 - DR to eu-west-1 (Ireland) — no PII replicated, only configuration and non-personal operational data
 - S3 bucket policies deny cross-region replication for buckets containing personal data
-

Principle 5 — Operational Resilience

Statement: Architecture must support FCA PS21/3 impact tolerances for important business services.

Rationale: FCA enforcement is in flight. Non-compliance risk is existential.

Implications:

- RTO $\leq$ 4 hours for critical IBS
 - RPO $\leq$ 1 hour for critical IBS
 - Multi-AZ for all production workloads
 - Regular DR tests documented and evidenced
-

Principle 6 — Cloud-Native First

Statement: We prefer cloud-native managed services over lift-and-shift where technically feasible.

Rationale: Maximises AWS investment, reduces operational overhead, supports long-term cost optimisation.

Implications:

- Aurora PostgreSQL preferred over Oracle (target: eliminate £1.4M/year licence)
 - DynamoDB for high-volume event data
 - EKS for container workloads
 - No EC2 if a managed service meets the requirement
-

Principle 7 — Cost Transparency

Statement: All AWS spend is tagged, tracked, and reviewed monthly.

Rationale: Board has approved £3.2M. Programme is under board-level scrutiny.

Implications:

- All resources tagged: Environment, Application, CostCentre, Owner, Programme
 - AWS Cost Explorer configured from Day 1
 - Monthly FinOps review with budget vs actual comparison
 - Reserved Instances / Savings Plans evaluated at 3-month mark
-

Principle 8 — Zero Trust Networking

Statement: No implicit trust based on network location. All access is authenticated and authorised.

Rationale: NCSC Cloud Security Principle 9. FCA expects robust access controls.

Implications:

- No public-facing resources except those explicitly required
 - All internal communication via private endpoints or VPC peering
 - WAF in front of all customer-facing services
 - IAM policy conditions enforce MFA for sensitive operations
-

TODO: Candidate Additions

- > Add at least 2 further architecture principles in Phase 2 based on your analysis of the Tilington estate.
- > Each principle must follow the format above: Statement, Rationale, Implications.
- > At least one must address the microservices/API design.